

Technology Services

Third-Party IT Security Guidelines

1. Purpose

Cyber security is fundamental to the successful operations of Southern Cross University (SCU). The Third-Party IT Security Policy and these guidelines have been prepared to standardise and guide the approach for establishing, implementing, maintaining, and continually improving the cyber security posture of SCU.

This guideline has been developed to assist business owners and relevant providers understand and implement the Third-Party IT requirements for SCU.

2. Scope and Background

This guideline applies to staff and providers of SCU and any personnel providing services on behalf of SCU.

Business owners must assess the benefits of using a Third-Party service balanced with the additional governance, privacy and security risks associated with such services.

Third-party IT offers potential benefits, including cost savings and improved business outcomes for the University agencies. However, there are information security risks that need to be carefully considered. The adopted third-party service model (IaaS, PaaS, SaaS) will often significantly impact responsibilities retained in-house and outsourced responsibilities.

3. Risk Based Approach

Risks will vary depending on the sensitivity of the data to be stored or processed and how the chosen Third-Party services provider has implemented their specific Third-Party services. Mitigating the risks associated with using third-party services is a responsibility shared by the university and third-party service providers. However, the service's risk will remain with the University and cannot be transferred.

4. Key Requirements

The following security considerations and recommended security mitigations must be considered when performing a Business or Risk Assessment on Third-Party service providers:

Security consideration	Mitigating controls
Maintaining availability and business functionality Business owners should identify and mitigate the risk of business functionality being negatively impacted by Third-Party services being unavailable. Understanding and documenting the availability requirements and preparing for business interruptive events are essential. • Business continuity planning • Availability requirements • Backup and recovery • Redundancy • System performance and service level agreements (SLAs).	Business continuity planning • Conduct a Risk Assessment to assess the business-critical data or functionality moving to the third party and understand the potential impact on the business operations during downtime or outage. • Review the Third-Party service provider's business continuity and disaster recovery plans to ensure that the Provider can respond to a significant incident or outage that affects their service delivery. • Assess the Provider's business continuity and disaster recovery plans that cover the availability and restoration of both data and the Provider's services and evaluate the alignment with the University's recovery objectives. • Understand and assess the time it takes for the data and services to be recovered after a disaster and how the Provider prioritises the recovery resources among all customers and subscription plans. • Assess the level of support and cooperation during offboarding or transferring from the current Third-Party service provider to a different Provider to ensure the University can access the data in a Provider-neutral format to avoid Provider lock-in. Availability requirements • Assess the network connectivity between the University and the Third-Party services for maintaining availability, including capabilities such as DoS protection, traffic throughput (bandwidth), preventing delays (latency) and packet loss. • Assess the Service Level Agreement (SLA) with the Provider and any assurances of availability, scheduled outage, and possible downtime that may impact/interfere with critical business



Security consideration	Mitigating controls
	processes. • Understand the scalability, horizontally and vertically, of the third-party services and available spare IT resources that the provider could provide to enable their services to scale when required. Backup and recovery • Assess the Third-Party service provider's capability of both full and partial systems recovery from backups, including the expected timeframes. • Assess the requirement of maintaining an up-to-date backup copy of data at the University's premises or stored with a second Provider with no common points of failure with the first Provider. • Assess the requirements for retaining backup copies, including the timeframe, format, security, and location for backup retention. Redundancy • Assess potential single points of failure associated with the Third-Party service and redundant facilities such as secondary failover sites and offsite backups to prevent disruptions of services. • Understand the requirement of replicating data or business functionality with a second Provider that uses a different data centre and ideally has no common points of failure with the first Provider. System performance and service level agreements (SLAs) Ensure Agreement arrangements are clearly defined and documented in the SLAs, including the following performance expectations: • System up-time and maximum acceptable downtime (99% system up-time, less than 9 hours outage per year). • Scheduled maintenance, changing windows, planned outages, communication mechanisms, and notification channels. • Response and resolution timeframe for unplanned outages, security incidents, and general request tickets. • Defined severity ratings and priority levels for general ICT and cyber security incidents. • Performance review frequency, reporting, and



Security consideration	Mitigating controls
	communication channel for performance and security monitoring. - Penalties for not meeting service levels or response/resolution timeframe that adequately reflect the damage caused by a breach of the SLA. The following security clauses must also be included in the Agreement with Third-Party service provider: - Appropriate protection applied to customer data or personal information (if applicable), including correctly deleting data from the Provider's storage media when terminating the Agreement. - Agree provisions for at least annual testing of failover and disaster recovery capabilities as a part of Agreement terms. - University to reserve the right to audit the security capabilities and controls maintained by the Third-Party service provider.
Protecting data from unauthorised access Unauthorised access to information and data stored on Third-Party services should be prevented. The third-party service provider and the customer often share the responsibility model for securing third-party environments. Business owners should understand the responsibilities of both parties and ensure Providers meet the requirements and expectations to protect data from unauthorised access. - Information classification and handling - Data security - Access control and monitoring - Physical security	Secure architecture design - Determine the Third-Party deployment model considering the information classification and public accessibility requirements of the Third-Party services. Deployment models include: - Public third-party (potentially less secure but accessible from the public networks) - Hybrid Third-Party or community Third-Party (potentially less accessibility but more secure) - Private third-party (potentially most secure but inaccessible from external networks). - If the Third-Party services are based on multi-tenant Third-Party infrastructure, the University should acquire assurance from the Provider for: - Customer segregation - adequate logical and network segregation is in place between multiple tenants. - Controls are in place to detect and prevent a tenant from exploiting a publicly unknown or unpatched vulnerability in a hypervisor to compromise another tenant's data. - Assess if the Third-Party service provider's security maturity and that of other customers can weaken the University's security posture. For example, malicious actors could use third-party infrastructure from the same provider used by the target organisation to serve malicious web



Security consideration	Mitigating controls
	content to the organisation's users and to exfiltrate the organisation's sensitive data. Information classification and handling • Understand the data security requirements associated with Third-Party Services. This should include the following: ○ sensitivity of datasets, as well as if the aggregation of data makes it more sensitive than any individual piece of data ○ information classification level ○ volume of data being stored or processed by the Third-Party services ○ any personal information stored in the Third-Party storage. • Understand the media sanitisation and data decommissioning requirements associated with Third-Party services. This includes the following: ○ Defined processes to sanitise the storage media storing data at its end-of-life. ○ When portions of data or databases are deleted, the defined processes to sanitise the storage media before it is made available to another customer. ○ When terminating the third-party service Agreement or subscription, the defined processes are used to delete data in storage media securely. Data security • Consider the requirements for encrypting data at rest; these include: ○ That the strength of the cryptographic algorithm is enough to protect the data at rest based on information classification and data sensitivity. ○ The implementation of encryption is comprehensive enough to cover all the storage, devices, and media that contain Third-Party service customer data and Third-Party service derived data. ○ That approved hash algorithms prevent brute force techniques from cracking and recovering relatively weak passwords and keys. • Consider the requirements of encrypting and protecting data in transit; these include:



Security consideration	Mitigating controls
	○ The cryptographic controls the Third-Party service provider uses to protect data in transit, such as TLS, HTTP, and SFTP. ○ The gateway environment is aligned with the University's security policies and standards to secure the network links and data in transit, including firewalls, traffic flow filters, content filters, antivirus software and data diodes. ○ Defined onboarding and change management processes to ensure that a legitimate source has supplied Third-Party infrastructure software and hardware and has not been maliciously modified in transit. • Consider the requirements of crucial management activities for data encryption. This includes the following: ○ Assess if the Provider provides a centralised critical management service to manage cryptographic keys for the University's Third-Party services consistently and securely. ○ Assess if the Provider supports key generation and rotation, which allows the University to generate new keys when needed and rotate the keys periodically to enhance security. ○ Assess if the Provider provides secure storage and protection for private keys, such as hardware security modules or software-backed encryption keys. Understand if the Provider provides features for centralised key storage and external or on-premise customer key storage. ○ Assess if the Provider provides robust access controls for encryption keys, including role-based access control, multifactor authentication (MFA) and privileged access management (PAM) tools to prevent unauthorised access. ○ Assess how the Provider manages critical suspension and destruction processes, ensuring suspended and retired keys are not used or accessible. • Consider hiding sensitive data (personal information) using techniques such as data masking, pseudonymisation or anonymisation. The examples are:



Security consideration	Mitigating controls
	○ Data masking is a set of techniques to conceal, substitute or obfuscate sensitive data items. Data masking can be static (when data items are masked in the original database), dynamic (using automation and rules to secure data in real-time) or on the fly (with data masked in an application's memory). ○ Anonymisation irreversibly alters personal information in such a way that the personal information principal can no longer be identified directly or indirectly. ○ Pseudonymisation replaces the identifying information with an alias. Knowledge of the algorithm (sometimes called the 'additional information') used to perform the pseudonymisation allows for at least some form of identification of the personal information principal. Therefore, such 'additional information' should be kept separate and protected. ● Consider the controls to prevent and mitigate data spills. The examples are: ○ Clarify the level of information classification and data sensitivities of the Third-Party services. Avoid uploading data that exceeds the defined security level. ○ If data the University considers too sensitive to be stored in the Third Party is accidentally placed into the Third Party (referred to as a data spill), ensure the spilled data can be deleted using forensic sanitisation or other data cleansing techniques. ● Ensure the relevant portion of physical storage media is purged and the timeframe for the deleted data is overwritten as part of regular operation.



Security consideration	Mitigating controls
	- Examine if the spilled data can be forensically deleted from the Provider's backup media and where else the spilled data is stored. Access control and monitoring - Third-party service providers should provide the following functionalities and security features to customers: - Support third-party identity and access management technologies for its Third-Party services and the associated administration interfaces. These technologies enable easier integration and user identity administration between the customer's system and the cloud service. They can make using multiple Third-Party services easier through capabilities such as single sign-on. - Secure authentication techniques for authenticating customer Third-Party service administrators to the administrative capabilities of a Third-Party service, according to the identified risks. For example, the Third-Party service provider can provide multi-factor authentication capabilities or enable third-party multi-factor authentication mechanisms. - Break glass accounts are provided as emergency access accounts used to access critical systems or resources when other authentication mechanisms fail or are unavailable. - Access logs, audit logs, login reviews, and reports for customers to perform access reviews and incident investigations. The logs should integrate with the customer's security information and event management (SIEM) system. - Business owners should check that the Provider's remote access is adequately monitored and managed if the Provider has access to University Third-Party infrastructure or application components, including: - understanding if the Provider needs to perform remote access from outside Australia - assurance from the Provider for patch compliance reports and other details about the security of workstations used to perform remote access - the controls that prevent the Provider's employees from using untrusted or



Security consideration	Mitigating controls
	personally owned devices to store or process customer data. Physical security • Examine the Provider's physical security posture and ensure the Provider's physical data centre is designed to prevent the tampering or theft of servers, infrastructure, and stored data. • Understand if dedicated servers are required for the University's Third-Party services and if the University has some control over the physical computer that runs the Third-Party services and virtual machines
Monitoring and reporting cyber security incidents Providers should have sufficient capabilities to monitor the security posture of Third-Party environments and report cyber security incidents to the customer. Business owners should understand if Providers can maintain the required level of incident response readiness and provide sufficient support during and after a cyber security incident. • Security Incident Response Plan (SIRP) • Logging and monitoring capability • Notification of security incidents	Provider support • Assess the level and scope of provider support and understand if the university can acquire timely and sufficient support to investigate, respond to, and resolve a cyber security incident associated with the third-party service. This includes the following aspects of Provider support: ○ The Provider is readily contactable and responsive to requests for support - an agreed communication channel is established to raise requests and exchange information. ○ The Provider assists University investigations if there is a security breach, such as an unauthorised disclosure of data, or if there is a need to perform legal electronic discovery of evidence. ○ The maximum acceptable response and resolution times are captured in the SLA, and that timeline is defined based on the severity and priority levels of the cyber security incident. While general ICT support during service outages and availability issues may be documented in Provider Agreements, the specific cyber security incident support requirements are commonly not agreed upon or documented in the SLA. ○ Understand if Provider support is provided within Australia from a foreign resource or several foreign countries and time zones. ○ The Provider adequately compensates the



Security consideration	Mitigating controls
	customer if the Provider's actions, faulty software or hardware contributed to a security breach. Incident response (IR) plan • Review the Provider's cyber security IR plan and understand how the Provider detects and responds to cyber security incidents. • Understand if the scope of the Provider's cyber security IR plan covers the services they delivered to the University. If the Provider offers additional or modified Third-Party services or functions to the University, ensure the Provider has updated the IR plan and procedures aligned with the offering. • Examine if the Provider performs regular testing of the IR plan and provides training to their employees to identify and report potential security incidents properly. Logging and monitoring capability • Assess the Provider's security monitoring capabilities and understand if they continuously monitor their IT environments and the Third-Party services they offer for cyber security events and incidents. • Understand if the University's existing security monitoring tools and SIEM solution can be integrated or connected with the Third-Party service. • Understand if the University must learn to use additional tools provided by the Provider to monitor the performance and security events of the Third-Party services and assess the capacity and resources needed to perform monitoring activities. • Understand if the University can access the logs generated by the Third-Party service and ensure the University can obtain access to audit logs and other logs to perform forensic investigations. • Assess if the log retention settings of the Third-Party services are aligned with the University requirements and compliance obligations. • Examine the logs from Third-Party services to ensure they are time synchronised with a trusted Network Time Protocol (NTP) server



Security consideration	Mitigating controls
	and that the logs are created and stored as suitable evidence for a court of law. Notification of security incidents - Examine the provider's procedures for notifying customers of security incidents within their corporate environments and the third-party services they provide to customers. This should also include if a cyber security incident occurs within a fourth party's environment (for example, the suppliers, contractors or third parties of the Provider). - Understand the reporting portal and communication channels that the Provider may use to notify the University of any cyber security incidents and the information required to be reported. - Understand if the Provider will automatically notify law enforcement or other authorities, who may confiscate IT equipment that stores or processes University data. The following security clauses must also be included in the Agreement with Third-Party service provider: - If the Third Party sustains a Cyber-attack where SCU's data has been breached, the Third Party must notify SCU within 48 hrs of the breach being detected.
Maintaining system integrity Any changes to the Third-Party service and data held within the Third-Party service should be recorded and managed to protect the system integrity and data quality. Business owners should understand how much the Provider can support identifying, correcting, and investigating integrity issues. - Change control - Audit trail - Data quality	Change control - Assess the Provider's change management processes to ensure that changes in Third-Party services and products are appropriately managed throughout the entire system development life cycle to maintain system integrity. - Examine the Provider's change control procedures and release control procedures to understand if they include the following elements: - plan and assess the potential impact of changes on customers - obtain approval and authorisation of changes from appropriate stakeholders - communicate changes to Third-Party service customers - test changes from functionality and security



Security consideration	Mitigating controls
	perspectives ○ maintain and provide records of changes to customers if required. • Understand if Third-Party service customers can track the changes and versions and roll back to the previous version if needed. Audit trail • Understand how the Third-Party service maintains an audit trail of activities the Provider and customer perform. • Understand how the Provider supports customers in setting up and accessing the audit trail and how to search, download, archive, analyse, respond to, and manage access to the audit trail. • Assess if the Provider or unauthorised personnel can delete or alter the audit trail to compromise the integrity and accuracy of the records. • Assess the location and media for storing the audit trail and logs to ensure it aligns with the University's log retention policy. Data quality • Understand how the Third-Party service provider standardises and maintains the consistency of data formats and database schemas. • Assess if the Provider offers built-in validation tools to help identify and correct errors or data inconsistencies or if the Third-Party service can be integrated with the University's existing data validation tools. • Examine if the Provider adheres to industry standards and can simplify integrating data from multiple sources or migrating data to another Provider or Third-Party service. • Assess if the Provider supports master data management (MDM) so the University can clean, match, and integrate data discovered across distributed storages and sources and use it to create master data objects stored in a central MDM system.
Maintaining compliance with legal and Agreement requirements Business owners should understand their obligations	Legislative obligations • Understand the data and information assets associated with the third-party services that the university has to protect and manage under applicable legislations and laws, such as SCU's

Security consideration	Mitigating controls
related to the Third-Party services and data uploaded to the Third-Party. Providers should be able to assist business owners in maintaining compliance with applicable regulations and security frameworks. Business owners should acquire sufficient assurance of compliance from the Provider using Agreement terms and security SLAs. • Legislative obligations • Data Ownership • Data sovereignty • Right to audit	record management policy or privacy policy. • Assess if the Provider accepts adhering to the obligations and helping the University to ensure that the commitments are met. • Understand the obligations and requirements of the NSW Cloud Policy that are associated with the Third-Party services, including the following: ○ Where the information to be maintained under Third-Party IT arrangements is of a highly sensitive or personal nature, confirm that any arrangement with a Third-Party service provider must involve storage of the records in a jurisdiction with a privacy regime equivalent to Australia's and with adequate security measures in place. ○ Ensure that all privacy requirements applicable to the University are considered and addressed in agreements with the Third-Party service provider. ○ Compliance with NSW standard ICT Agreement (ICTA) • Understand the obligations and requirements of NSW Records Management Policy, including if: ○ the transfer or storage of official records outside of state or country boundaries is permitted under local regulatory frameworks and University policy. ○ If agreement terms address data sovereignty issues to the satisfaction of the University. Specifically, these terms should establish and agree to the location of all Third-Party service provider data held on behalf of the University under the Agreement terms. Consider the location of: ▪ The primary data store ▪ replication of data to support high-availability solutions or authentication ▪ online and offline backup administration and support staff who may access the processing environment and data. Data Ownership



Security consideration	Mitigating controls
	• Understand the Agreement terms and agreements on data ownership. Ensure the University retains legal ownership of the data stored or processed by the Third-Party service. • Assess how the Provider protects the intellectual property (IP) and the ownership of the information assets generated by the University while using the Third-Party Services. Data sovereignty • Understand in which countries the University's data is stored, transmitted, and processed. Data stored outside of Australia may be subject to the laws and regulations of the host country. These laws may not align with Australian privacy regulations and may allow foreign governments to subpoena data. • Understand if the Provider has failover or redundant data centres supporting Third-Party services and having access to the University's data. For example, university data held in an Australian data centre could be duplicated in a secondary data centre outside Australia for business continuity purposes. • Assess if the Provider has a documented procedure to notify customers of changes in data sovereignty and foreign ownership of the company or facilities. For example, a foreign-owned Provider may be subject to their country's laws even if it operates within Australia. If the Provider is subpoenaed by a foreign law enforcement organisation for access to data belonging to its customers, the Provider may be legally prohibited from notifying their customers of the subpoena. Right to audit • Maintain the right to perform security audits on the Provider's cyber security posture and relevant controls. If auditing is impossible, ensure a reputable third party has conducted audits and relevant control testing on the Provider. The right to audit should be defined in the Agreement and include the following requirements: ○ Review the policies and processes supporting the Provider's cyber security posture, including threat and risk assessments, ongoing vulnerability management, a change management process that incorporates security, regular penetration testing, logging and regular log analysis, incident management,

Security consideration	Mitigating controls
	access management, and compliance with Australian Government or internationally recognised security standards and regulations. ○ Assess the technical controls supporting the Provider's cyber security posture, including timely application of security patches, regularly updated antivirus software, defence in depth mechanisms to protect against unknown vulnerabilities, hardened operating systems and software applications configured with the most robust possible security settings, cryptographic protocols and processes, intrusion detection and prevention systems, and data loss prevention mechanisms. • Understand what level of internal audits the Provider performs and which compliance standards and other recommended practices from organisations such as the Third-Party Security Alliance are used for these assessments. Review a copy of the recent reports. • Review copies of independent assurance reports of certification to information security standards, including the specific Third-Party services being used within scope. Where possible, the Agreement should outline that regular copies of certification and maintenance audits are provided for review. Examples of relevant security certifications include IRAP (Australia), ISO/IEC 27001, and SOC 2

5. On-boarding

This section details the procurement approach process and criteria for conducting due diligence and evaluating potential third parties to ensure they align with SCU's Risk Management objectives and risk thresholds.

5.1 Due Diligence Process

5.1.1 Initial Screening

Prospective Third Parties undergo an initial screening, where basic information about their business, financial stability, and market reputation is collected and reviewed. This preliminary step determines if the vendor meets SCU's fundamental criteria and standards.

5.1.2 Comprehensive Due Diligence

After passing the initial screening, a more thorough due diligence process begins. This includes Business or Risk Assessments, compliance reviews, operational resilience evaluations, and reference checks.

5.1.3 Risk Assessment

A risk assessment compares the identified risks against SCU's predefined risk thresholds. This includes evaluating the data sensitivity rating, results of security and compliance reviews, and other relevant risk factors.

5.1.4 Approval and Risk Mitigation

If the vendor meets or exceeds SCU's Risk Management objectives and falls within acceptable risk thresholds, they proceed to final approval. Any risks identified that exceed acceptable levels must be mitigated through additional controls, revised contract terms, or specific vendor commitments before proceeding.

5.1.5 Penetration Testing

The business owner shall ensure the penetration test is completed for Third Parties likely to store, transmit and use sensitive or personally identifiable information. These tests should be performed regularly, including when there are changes to the environment, primary functionality or new versions. The results will be shared with the Cyber Resilience team to identify vulnerabilities and monitor corrective actions. This testing assesses the security of the vendors' systems by simulating cyber-attacks.

5.1.6 Contract Finalisation

Once all risk mitigation strategies are in place, a contract can be finalised upon completing the due diligence and risk assessment processes. The contract will include necessary clauses related to compliance, data security, risk management responsibilities, and penalties for non-compliance.

5.1.7 Vendor Onboarding

The vendor is formally onboarded and integrated into SCU's systems and processes. This includes providing access to necessary resources, conducting training on compliance and security requirements, and establishing lines of communication for ongoing management and reporting.

5.1.8 Outcomes of Failed Due Diligence

If a prospective Third Party fails the due diligence by not meeting the required security, compliance, or operational standards, or if they pose a risk beyond SCU's defined tolerance, the pending partnership may be terminated.

Where the Business Owner views that the business value is likely to outweigh any perceived risk, the Business Owner should seek exemption through the Director of Cybersecurity, outlining the business benefit.

6. Off-boarding

This section outlines the procedures and associated with the offboarding of Third-party agreements.

6.1 Formal termination:

Any agreement will be formally terminated per the terms specified within the agreement. Access to all organisational resources, data, and systems will be revoked, and the third party must comply with all Agreement exit requirements, including the return or destruction of confidential information. The Business Owner shall complete the 'Third Party Offboarding Checklist' (Appendix A) and forward a copy to SCU's Procurement and Technology Services Cyber Resilience teams.

6.2 Legal and financial considerations

The termination process will consider any legal implications or financial liabilities incurred by either party. This includes penalties, any outstanding payments, and damages. Legal counsel should review all termination actions to ensure compliance with contractual terms and applicable laws.

6.3 Documentation and record-keeping

All proceedings related to contract termination must be thoroughly documented, including the initial notice, communications, actions taken by the vendor, and final termination notices. These records are essential for legal and auditing purposes.

7. Related Documents and Information

1. [ACSC Cyber Supply Chain Risk Management](#)
2. [NIST Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#)
3. [NSW Cloud policy](#)
4. [SCU Risk Management Framework](#)
5. [SCU Information Asset Classification Policy](#)
6. [SCU Information Technology \(IT\) Security Policy](#)
7. [SCU Information Technology - Third Party - Security Policy](#)

8. Document control

These guidelines shall be subject to periodic review to ensure currency and relevancy.

Document owner:		Director, Cyber Security		
Document approver:		Director, Cyber Security		
Classification:		Official		
Compliance				
Essential 8		NA		
ISM		ISM-1631, ISM-1452, ISM-1567, ISM-1568, ISM-1882, ISM-1632, ISM-1569, ISM-1785, ISM-1786		
NIST		NIST SP 800-161r1		
Revision				
Version	Approved by	Reason for Change	Approval date	Review due
V1	Dir, Cyber Security	Initial	10 Oct 2024	

APPENDIX A – THIRD-PARTY OFFBOARDING CHECKLIST

Third-Party Email: _____

Reason for Offboarding: _____

Date of Termination: DD/MM/YYYY

Notify Third Party of Agreement Termination:

- ☐ Third Party Account Manager
- ☐ Third Party Billing Department
- ☐ Third Party Customer Support

Review Agreement Obligations and Termination Clauses:

- ☐ Confirm Agreement obligations have been met.
- ☐ Notify Third Party of termination in compliance with Agreement terms.
- ☐ Address any outstanding Agreement matters.

Confirm all outstanding invoices and payments:

- ☐ Verify any outstanding invoices.
- ☐ Arrange for final payment if necessary.
- ☐ Obtain confirmation of payment receipt if required.

Return any Third Party-owned assets or equipment:

- ☐ List Third Party assets to be returned.
- ☐ Arrange for the return of equipment or materials.
- ☐ Obtain confirmation of asset return.

Ensure the secure transfer or deletion of data and information:

- ☐ Data Transfer Plan (as applicable).
- ☐ Data Deletion/Destroy Documentation (as applicable).

Develop a transition plan for replacing Third Party services/products:

- ☐ Identify alternative Third Parties or solutions.
- ☐ Set timelines and milestones for transition.
- ☐ Allocate necessary resources for transition.

Notify internal stakeholders and employees about the Third Party offboarding.

- ☐ Inform relevant departments of the Third-Party termination.
- ☐ Communicate changes to affected employees.

Ensure compliance with legal and regulatory requirements.

- ☐ Review any legal implications.
- ☐ Notify relevant authorities if needed.

Archive and retain necessary documents and records.

- ☐ Archive Agreements, invoices, and correspondence.
- ☐ Ensure records are accessible if needed in the future.

Gather feedback on the Third-Party relationship.

- ☐ Conduct an exit interview or survey.
- ☐ Document lessons learned for future Third Party relationships.

Revoke Third Party access to company systems and premises.

- ☐ Deactivate third-party accounts.
- ☐ Collect keys, access cards, or credentials.

Arrange a final meeting with the Third Party for closure.

- ☐ Discuss any outstanding matters.
- ☐ Express appreciation for the partnership.

Ensure that all checklist items have been completed.

- ☐ Obtain necessary approvals and sign-offs.

Date of Third-Party Offboarding: DD/MM/YYYY

Offboarding Owner/Responsible Person: _____

Additional Notes: